

Resolução - Lista de Exercícios: Segurança Digital

Nome: Pedro Henrique de Brito Canabarro

Parte 1 - Visão Geral da Segurança da Informação (Aula 01)

Questão 1 - Defina, com suas palavras, os três pilares da tríade CIA (Confidencialidade, Integridade e Disponibilidade) e dê um exemplo prático de um incidente que viole cada um deles.

- **Confidencialidade:** É a garantia de que a informação seja acessível apenas por pessoas ou sistemas autorizados.

Exemplo de Violação: Um banco de dados contendo registros médicos de pacientes de uma clínica vaza na internet e fica acessível para o público geral.

- **Integridade:** É a garantia de que a informação seja mantida exata, completa e imutável contra modificações não autorizadas.

Exemplo de Violação: Um invasor consegue interceptar e alterar o valor do boleto de pagamento de uma empresa antes dele ser enviado para o cliente.

- **Disponibilidade:** É a garantia de que os sistemas e informações estejam operacionais e acessíveis para uso quando solicitados por usuários autorizados.

Exemplo de Violação: Um ataque de negação de serviço (DDoS) derruba os servidores de um aplicativo de entregas num sábado à noite, impedindo os clientes de realizarem pedidos.

Questão 2 - Relacione cada termo à sua definição correta:

A ordem correta, de cima para baixo, é: **(c), (e), (a), (d), (b)**.

- **(c) Ativo:** Qualquer recurso de valor para a organização (dado, sistema, pessoa, reputação).
- **(e) Ameaça:** Evento ou agente potencialmente capaz de causar dano a um ativo.
- **(a) Vulnerabilidade:** Fraqueza que pode ser explorada para comprometer um ativo.
- **(d) Risco:** Probabilidade de uma ameaça explorar uma vulnerabilidade, combinada ao impacto resultante.
- **(b) Controle:** Medida (técnica, administrativa ou física) para reduzir a exposição a um risco.

Parte 2 - Fundamentos de Redes e Introdução a Testes de Invasão (Aula 02)

Questão 3 - Dado o endereço de rede 192.168.10.0/26, calcule:

- a) A máscara de sub-rede em notação decimal: 255.255.255.192 (são 26 bits para rede).
- b) O número de hosts utilizáveis por sub-rede: 62 hosts utilizáveis. (A fórmula é $2^6 - 2$).
- c) O endereço de broadcast da sub-rede: 192.168.10.63.
- d) O primeiro e o último endereço de host válidos: Primeiro IP válido: 192.168.10.1. Último IP válido: 192.168.10.62.

Questão 4 - Descreva, em ordem, as fases de um teste de invasão (pentest) e explique brevemente o objetivo de cada fase.

1. **Planejamento e Reconhecimento (Information Gathering):** Fase de definição do escopo (o que pode ou não ser atacado) e da coleta de informações do alvo (domínios, IPs abertos, nomes de funcionários) utilizando fontes abertas (OSINT) e análise de rede.
2. **Varredura (Scanning / Enumeração):** Utilização de ferramentas técnicas (como o Nmap) para identificar portas abertas, serviços em execução e descobrir possíveis vulnerabilidades no ambiente mapeado.
3. **Exploração (Exploitation):** Onde o ataque acontece de fato. Busca-se usar as vulnerabilidades encontradas na fase de varredura para comprometer e ganhar acesso aos sistemas, interceptar tráfego ou burlar proteções.
4. **Pós-Exploração:** Fase em que o invasor, já dentro do sistema, busca manter o acesso (persistência), escalar seus privilégios (virar administrador), realizar movimentação lateral para outras máquinas da rede e extrair dados sensíveis.
5. **Relatório (Reporting):** Elaboração do documento final para o cliente detalhando as vulnerabilidades encontradas, as metodologias aplicadas, o impacto que os ataques poderiam causar no negócio e as sugestões de mitigação e correções técnicas.

Parte 3 - Protocolos de Rede, DHCP e NAT (Aula 03)

Questão 5 - Descreva o processo DORA do DHCP (Discover, Offer, Request, Acknowledge), explicando o que acontece em cada uma das quatro etapas.

- **Discover (Descobrir):** O cliente, ao se conectar na rede e não possuir um IP, envia uma mensagem em broadcast na rede local perguntando "Existe algum servidor DHCP aqui?".
- **Offer (Oferecer):** O servidor DHCP escuta a solicitação e responde oferecendo um endereço IP disponível do seu escopo, além de informações de máscara de rede.
- **Request (Requisitar):** O cliente recebe a oferta e responde (normalmente via broadcast) confirmando que deseja ficar com aquele endereço IP e demais configurações (como Gateway e DNS).
- **Acknowledge (Confirmar):** O servidor DHCP recebe a requisição, marca o IP como em uso no seu controle (lease) e envia uma mensagem ACK ao cliente, finalizando a configuração e permitindo que o cliente comece a usar a rede.

Questão 6 - Explique a diferença entre NAT estático, NAT dinâmico e PAT. Qual é a mais utilizada em redes domésticas e por quê?

- **NAT Estático (Static NAT):** Mapeia permanentemente e de forma manual um endereço de IP privado específico para um endereço IP público específico (relação um-para-um fixa).
- **NAT Dinâmico (Dynamic NAT):** Mapeia IPs privados para IPs públicos selecionando-os temporariamente a partir de um "pool" (reserva) de IPs públicos disponíveis (relação um-para-um móvel).
- **PAT (Port Address Translation / NAT Overload):** Mapeia múltiplos IPs privados de uma rede local para utilizar um único (ou poucos) endereço de IP público. A distinção de qual pacote pertence a qual máquina privada é feita utilizando as portas lógicas de origem (TCP ou UDP) diferentes.
- **Mais utilizada em redes domésticas:** O PAT é o mais utilizado. Isso se deve ao fato de que os provedores de internet (ISPs) normalmente fornecem apenas um único endereço IP público por residência. O PAT permite que vários dispositivos diferentes (celulares, TVs, computadores) consigam navegar na internet simultaneamente utilizando este IP público único sem que haja conflitos de rota.

Parte 4 - Varredura de Portas e Enumeração de Serviços (Aula 04)

Questão 7 - Descreva as três etapas do three-way handshake do TCP e explique como o SYN Scan

(-sS) do Nmap se aproveita desse processo.

- **Three-way handshake:**
 1. **SYN:** O cliente envia um pacote com a flag SYN para o servidor, pedindo para iniciar uma conexão e sincronizar números de sequência.
 2. **SYN-ACK:** O servidor, estando com a porta aberta e pronto, recebe o pedido e responde com um pacote SYN-ACK (aceitando o sincronismo e enviando o dele).
 3. **ACK:** O cliente responde com um pacote ACK para confirmar o recebimento. Com isso, a conexão é perfeitamente estabelecida e os dados podem trafegar.
- **Como o SYN Scan (-sS) tira proveito disso:** O SYN Scan também é conhecido como *Stealth Scan* (scan furtivo) ou "meia-conexão". O Nmap manda o **SYN**. Se a porta estiver aberta, o alvo devolve o **SYN-ACK**. Porém, neste momento, em vez do Nmap finalizar a conexão enviando o **ACK**, ele abandona a conexão e envia um pacote **RST** (Reset) para cancelar e derrubar imediatamente o handshake. Ele faz isso porque, ao receber o SYN-ACK, ele já atingiu seu objetivo: descobrir que a porta está *aberta*. Como a conexão nunca é finalizada de fato, esse scan é muito mais rápido e antigamente evitava ser registrado nos logs da maioria dos aplicativos, já que eles costumavam registrar apenas conexões completas.

Questão 8 - Para cada comando Nmap abaixo, explique o que ele faz:

- **a) nmap -sS -p 1-1000 192.168.1.0/24:** Realiza um TCP SYN Scan (Stealth) (-sS) buscando identificar as portas abertas especificamente no intervalo de 1 a 1000 (-p 1-1000), varrendo em todos os endereços da sub-rede 192.168.1.0/24.
- **b) nmap -sV -O 192.168.1.10:** Executa um scan no host 192.168.1.10 tentando detectar ativamente as versões exatas dos softwares e serviços rodando nas portas abertas (-sV) e usa fingerprinting para tentar identificar qual é o Sistema Operacional (-O) do alvo.
- **c) nmap -sU -p 53,161 192.168.1.10:** Realiza uma varredura exclusiva no protocolo UDP (-sU), sondando apenas as portas 53 (usada pelo DNS) e 161 (usada pelo SNMP) no host alvo 192.168.1.10.
- **d) nmap -T4 -A -oN resultado.txt 192.168.1.10:** Executa um scan Agressivo (-A) (que habilita simultaneamente detecção de SO, versão de serviços, scripts padrão e traceroute) numa velocidade de tempo rápida (-T4, que é mais intrusivo), apontado ao host 192.168.1.10, e salva todo o relatório da saída no formato normal em um arquivo de texto chamado "resultado.txt" (-oN).

Parte 5 - Kali Linux e Linha de Comando (Aula 05)

Questão 9 - Explique o significado de cada campo na permissão abaixo e converta-a para notação octal:

`-rwxr-xr-- 1 root root 4096 ago 24 10:00 scan.sh`

- **-** : O primeiro traço indica o tipo de arquivo. Nesse caso, é um arquivo regular normal (se fosse "d", seria um diretório).
- **rwx** : Representa as permissões do Proprietário (User). Ele tem permissão de leitura (r = 4), gravação (w = 2) e execução (x = 1). Total: 7.
- **r-x** : Representa as permissões do Grupo (Group). Têm permissão de leitura (r = 4) e execução (x = 1). Faltam permissões de gravação. Total: 5.
- **r--** : Representa as permissões para Outros Usuários (Others). Têm permissão apenas de leitura (r = 4). Total: 4.
- **1** : Número de links (atalhos) físicos apontando para o arquivo.
- **root (primeiro)**: O nome do usuário proprietário do arquivo.
- **root (segundo)**: O nome do grupo dono do arquivo.
- **4096** : O tamanho do arquivo em bytes.
- **ago 24 10:00** : A data e a hora da última modificação feita no arquivo.
- **scan.sh** : O nome do arquivo.
- **Conversão Octal**: 7 (rwx) + 5 (r-x) + 4 (r--). Portanto, a notação octal é **754**.

Questão 10 - Qual a diferença entre os comandos su e sudo em um sistema Linux? Por que ferramentas de varredura como o Nmap frequentemente exigem sudo para determinados tipos de scan?

- **Diferença entre su e sudo**: O comando **su** (*Substitute User*) permite que você troque a sessão inteira do seu terminal para a de outro usuário (geralmente o usuário root). Para usá-lo, você precisa saber a *senha do usuário alvo*. Já o comando **sudo** (*Superuser DO*) permite que você execute comandos específicos pontualmente com os privilégios do root. Para usá-lo, você não precisa saber a senha do administrador, você deve digitar *a sua própria senha* (desde que seu usuário atual esteja registrado no arquivo de permissões `/etc/sudoers`).
- **Por que o Nmap exige sudo para scans como -sS**: Tipos de scan avançados, como o SYN Scan (-sS) ou o UDP Scan (-sU), não usam a pilha normal de conexões de rede do sistema operacional. O Nmap precisa construir, modificar e enviar pacotes puros "na mão" (conhecidos como *raw sockets*). Por motivos de segurança, o kernel do Linux restringe a criação de pacotes customizados

de *raw sockets* apenas a usuários com privilégios máximos de administrador. Portanto, o Nmap precisa do *sudo* para obter permissão para criar esses pacotes não convencionais e realizar a quebra do aperto de mão (handshake) na placa de rede.